

Clase 210 — Forense de navegadores y correo

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *SANS FOR500* y documentación de formatos de navegador/correo 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

Objetivo

Aprender a extraer y analizar la actividad web y de correo: historial, cookies, descargas, caché y sesiones de navegadores (Chrome, Firefox, Edge), y encabezados, adjuntos y trazabilidad de correos. Al terminar podrás reconstruir la navegación de un usuario y analizar el origen real de un correo de phishing.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Localizar y parsear** las bases SQLite de los navegadores.
2. **Reconstruir** historial, descargas y sesiones de navegación.
3. **Analizar** encabezados de correo para trazar el origen real.
4. **Extraer** adjuntos y detectar phishing y spoofing.
5. **Correlacionar** actividad web/correo con la timeline del caso.

Temas

#	Tema	Por qué importa
1	Bases de datos de navegador	Historial, cookies, descargas
2	Chrome/Edge (History, Cookies)	Formato SQLite dominante
3	Firefox (places.sqlite)	Estructura propia
4	Caché y sesiones	Contenido y pestañas abiertas
5	Formatos de correo (PST, OST, MBOX, EML)	Dónde vive el correo
6	Encabezados de correo	Trazar origen real
7	SPF/DKIM/DMARC	Detectar spoofing
8	Adjuntos y phishing	Vector de entrada común

Definiciones y características

- **History (Chrome):** SQLite con visitas, tiempos y descargas. Característica: los timestamps usan época WebKit (microsegundos desde 1601).
- **places.sqlite (Firefox):** base de historial y marcadores. Característica: timestamps en microsegundos desde 1970.
- **Cookies:** sesiones y autenticación persistidas. Característica: pueden probar acceso a un servicio.

- **PST/OST**: contenedores de Outlook. Característica: PST es exportable; OST es la caché local.
- **MBOX/EML**: formatos de correo de texto. Característica: EML es un mensaje individual con encabezados completos.
- **Encabezados Received**: cadena de servidores por los que pasó el correo. Característica: se leen de abajo hacia arriba para trazar el origen.
- **SPF/DKIM/DMARC**: mecanismos de autenticación del remitente. Característica: sus fallos delatan spoofing.

Herramientas y preparación

- **Navegadores**: DB Browser for SQLite, herramientas de Eric Zimmerman, Hindsight (Chrome), nirsoft BrowsingHistoryView.
- **Correo**: libpff (PST), readpst, un visor de EML, y análisis manual de encabezados.
- **Entorno**: usa perfiles de navegador y correos PROPIOS. Si analizas un correo de phishing real recibido por ti, hazlo en entorno aislado y no abras los adjuntos.

Laboratorio guiado

Usa tu propio perfil de navegador y correos propios.

1. Copia (no abras el navegador en vivo) la base de historial de Chrome: - Windows:

`%LOCALAPPDATA%\Google\Chrome\User Data\Default\History`.

2. Explora el historial con SQL:

```
sql SELECT url, title, visit_count, last_visit_time FROM urls ORDER BY last_visit_time DESC;
```

3. Convierte los timestamps WebKit a fecha legible (recuerda: microsegundos desde 1601).

4. Analiza Firefox:

```
sql SELECT url, title, visit_count FROM moz_places ORDER BY last_visit_date DESC;
```

5. Usa Hindsight para un informe consolidado de Chrome (historial, cookies, descargas, extensiones).
6. Analiza un correo de phishing propio (archivo `.eml`): abre los encabezados y lee la cadena `Received` de abajo hacia arriba para hallar el servidor de origen real.
7. Verifica autenticación del remitente: - Revisa `Authentication-Results` para ver el resultado de SPF, DKIM y DMARC. - Un `spf=fail` o `dkim=fail` con dominio suplantado indica spoofing.
8. Extrae el adjunto sin ejecutarlo y calcula su hash SHA-256 para contrastarlo contra VirusTotal (solo el hash, no subas datos sensibles).

Ejercicios

1. Convierte tres timestamps WebKit a fecha UTC legible.
2. Lista las diez URLs más visitadas de tu perfil.
3. Reconstruye una descarga con su origen y destino.
4. Traza el origen real de un correo leyendo sus `Received`.
5. Detecta spoofing con `Authentication-Results`.
6. Extrae y hashea un adjunto sin abrirlo.

Reto verificable

Analiza un correo de phishing propio y demuestra que el remitente está suplantado, identificando el servidor de origen real y el resultado de SPF/DKIM/DMARC, y correlaciona una URL del correo con el historial del navegador.

Criterio de aceptación: reportas (a) el servidor de origen real desde la cadena `Received`, (b) los resultados de SPF/DKIM/DMARC que prueban el spoofing, y (c) evidencia de si el usuario visitó la URL maliciosa (o no) según el historial.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>database is locked</code>	El navegador está abierto. Trabaja sobre una copia con el navegador cerrado.
Timestamps sin sentido	Épocas distintas (WebKit vs. Unix). Convierte con la fórmula correcta.
Encabezados <code>Received</code> confusos	Léelos de abajo hacia arriba; los de arriba pueden estar falsificados.
SPF pasa pero igual es phishing	SPF valida el sobre, no el <code>From</code> visible. Revisa DKIM y DMARC.
Adjunto peligroso	Nunca lo ejecutes. Solo hashea y analiza en aislamiento.

Preguntas frecuentes

 **¿Por qué timestamps raros en Chrome?** Usa la época WebKit: microsegundos desde el 1 de enero de 1601. Hay que convertirla.

 **¿SPF suficiente contra spoofing?** No. SPF valida el remitente del sobre (envelope), no el `From` que ve el usuario. DMARC alinea ambos; revísalo siempre.

 **¿Puedo recuperar correo borrado?** A veces sí desde PST/OST (elementos recuperables) o desde el espacio no asignado con carving.

 **¿El modo incógnito deja rastro?** En disco casi no, pero puede quedar en memoria, DNS caché y logs del proxy o del servidor.

Referencias

- SANS — Windows Forensic Analysis (FOR500): <https://www.sans.org/>
- Hindsight (Chrome forensics): <https://github.com/obsidianforensics/hindsight>
- libpff (PST/OST): <https://github.com/libyal/libpff>
- RFC 5322 (formato de mensaje) y RFC 7208 (SPF): <https://www.rfc-editor.org/>

Siguiendo clase

Clase 211 - Forense móvil